Enterprise Security Guide & Operating Manual

Chapter 1: Zero Trust Architecture Overview

Acme Corp enforces a strict Zero Trust Architecture (ZTA) across all infrastructure zones. Under the Zero Trust paradigm, no actor, service, network segment, or device is implicitly trusted, whether originating from inside or outside the physical perimeter. Every access request must be explicitly authenticated, authorized, and cryptographically verified prior to granting resource access.

Identity verification requires hardware-bound FIDO2 WebAuthn multi-factor authentication (MFA) for all employees. SMS-based and email-based two-factor authentication methods are strictly prohibited due to SIM-swapping and adversary-in-the-middle phishing vulnerabilities.

Network micro-segmentation isolates production workloads from staging, QA, and corporate development environments. Cross-boundary communication is permitted exclusively over mutual TLS (mTLS) with short-lived X.509 certificates.

Chapter 2: Cryptographic Key & API Token Lifecycle

All programmatic credentials, service accounts, and API keys must adhere to centralized lifecycle rotation guidelines:

1. Production Service API Keys: Must be cryptographically rotated every 30 days. Any API key exceeding 45 days of age is automatically deactivated by the automated IAM reaper daemon.

2. Development and Staging Tokens: Must be rotated every 60 days. Hardcoding credentials or API keys in source code repositories is categorized as a Tier-1 security violation.

3. Key Custodianship: Master encryption keys (KEKs) must be housed in dedicated FIPS 140-2 Level 3 Hardware Security Modules (HSMs). Envelope encryption using AWS KMS or HashiCorp Vault is mandatory for all data at rest.

Emergency Key Revocation: In the event of a suspected leak or credential exposure, security operators must execute the command 'sec-ops token revoke --all-active' within 5 minutes of incident declaration.

Chapter 3: Incident Response Classifications & SLAs

Security incidents are triaged into three severity tiers based on blast radius and threat impact:

Severity 1 (Critical / Data Compromise): Unauthorized access to customer PII, active ransomware, or compromise of production root keys. Maximum initial response SLA is exactly 15 minutes. Executive leadership and legal counsel must be notified within 60 minutes.

Severity 2 (High / Service Disruption): Targeted DDoS attack, single-tenant data isolation failure, or localized service disruption without data exfiltration. Maximum initial response SLA is 60 minutes.

Severity 3 (Medium / Vulnerability Finding): High-risk CVE discovered in non-critical library or misconfigured cloud storage bucket. Response SLA is 24 hours, with remediation SLA of 7 calendar days.

Chapter 4: Regulatory Compliance & Cryptographic Standards

Acme Corp maintains annual certification under SOC 2 Type II, ISO 27001:2022, and HIPAA Security Rules. Independent SOC 2 surveillance audits occur bi-annually every June and December.

Approved Cryptographic Algorithms for Data at Rest and in Transit:

• Symmetric Data Encryption: AES-256 in Galois/Counter Mode (AES-256-GCM) with 96-bit initialization vectors.
• Asymmetric Signatures: ECDSA using NIST P-384 curves or RSA-4096.
• Hashing Algorithms: SHA-384 or SHA-512. MD5 and SHA-1 are strictly forbidden in all systems.
• In-Transit Protocol: Transport Layer Security (TLS) version 1.3 exclusively. TLS 1.0, 1.1, and 1.2 are disabled on all endpoints.

Audit Logging: All privileged administrative actions generate cryptographically signed audit logs stored in an immutable WORM (Write Once, Read Many) S3 bucket with a compulsory retention period of 7 years.